



Task thực tập

DFIR

Mentor: Đặng Ngọc Chiến
Executed by: Mai Bách Huyền

Tp. Hồ Chí Minh, tháng 6/2026



Mục lục

1	Giả lập tấn công	2
1.1	Kịch bản thực thi	2
1.1.1	T1059.003 (Command and Scripting Interpreter)	2
1.1.2	T1087.001 (Discovery: Local Account Discovery)	3
1.1.3	T1003.001 (Credential Access: OS Credential Dumping - LSASS Memory)	6
1.1.4	T1547.001 (Persistence: Run Keys)	7
2	Incident Response - Thu thập log (CDIR)	9
2.1	Ngữ cảnh cảnh báo	9
2.2	Mục tiêu Phase	9
2.3	Nguyên tắc thu thập forensic-safe	9
2.4	Quá trình thu thập và Kết quả	9
3	DFIR Analysis - Phân tích log bằng Hayabusa	11
3.1	Mục tiêu và phương pháp	11
3.2	Cơ sở lựa chọn nguồn log	11
3.3	Bước 1: Sanity check — Khảo sát tổng quan dataset	12
3.4	Bước 2: Triage theo mức độ nghiêm trọng — Xác định máy nghi nhiễm	12
3.5	Bước 3: Chọn Anchor Event	13
3.6	Bước 4: Mở rộng ruleset để lấy đủ ngữ cảnh	14
3.7	Bước 5: Pivot xung quanh Anchor Event	14
3.8	Ghi chú: Phạm vi nguồn log trong kết quả phân tích	16
4	Báo cáo DFIR	17
4.1	Executive Summary	17
4.2	Attack Timeline	17
4.3	Indicators of Compromise (IOCs)	17
4.4	Khuyến nghị	17

1 Giả lập tấn công

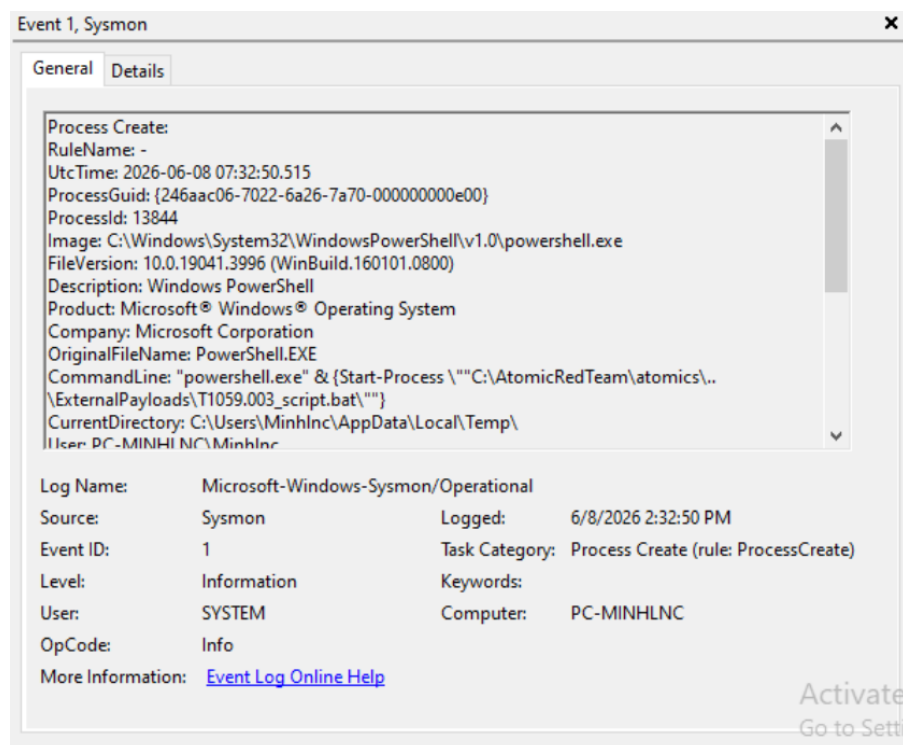
1.1 Kịch bản thực thi

Tiến hành giả lập 4 kỹ thuật theo chuẩn MITRE ATT&CK bằng công cụ Atomic Red Team:

- **T1059.003 (Execution):** Command execution.
- **T1087.001 (Discovery):** Account Discovery.
- **T1003.001 (Credential Access):** OS Credential Dumping.
- **T1547.001 (Persistence):** Run Keys.

1.1.1 T1059.003 (Command and Scripting Interpreter)

- **Khái niệm:** Lạm dụng các trình thông dịch lệnh (Command-line interface) hợp lệ và có sẵn của hệ điều hành như Windows Command Shell hoặc PowerShell để thực thi mã độc.
- **Hành vi thực thi:** Kẻ tấn công chạy các script độc hại hoặc truyền lệnh trực tiếp thông qua terminal nhằm tương tác với hệ thống, tải payload từ xa, hoặc thay đổi cấu hình bảo mật.
- **Dấu vết để lại:** Sự xuất hiện của Process Creation logs (Sysmon Event ID 1) ghi nhận cmd.exe hoặc powershell.exe được gọi với các tham số bất thường.



Hình 1: Log Sysmon Event ID 1 ghi nhận tiến trình PowerShell thực thi batch script (T1059.003)

```
PS C:\Users\MinhInc\Downloads\hayabusa-3.9.0-win-x64> Invoke-AtomicTest T1059.003 -TestNumbers 1
PathToAtomsFolder = C:\AtomicRedTeam\atomics

Executing test: T1059.003-1 Create and Execute Batch Script
Exit code: 0
Done executing test: T1059.003-1 Create and Execute Batch Script
PS C:\Users\MinhInc\Downloads\hayabusa-3.9.0-win-x64>
```

Hình 2: Log Sysmon Event ID 1 ghi nhận cmd.exe khởi chạy kịch bản PowerShell

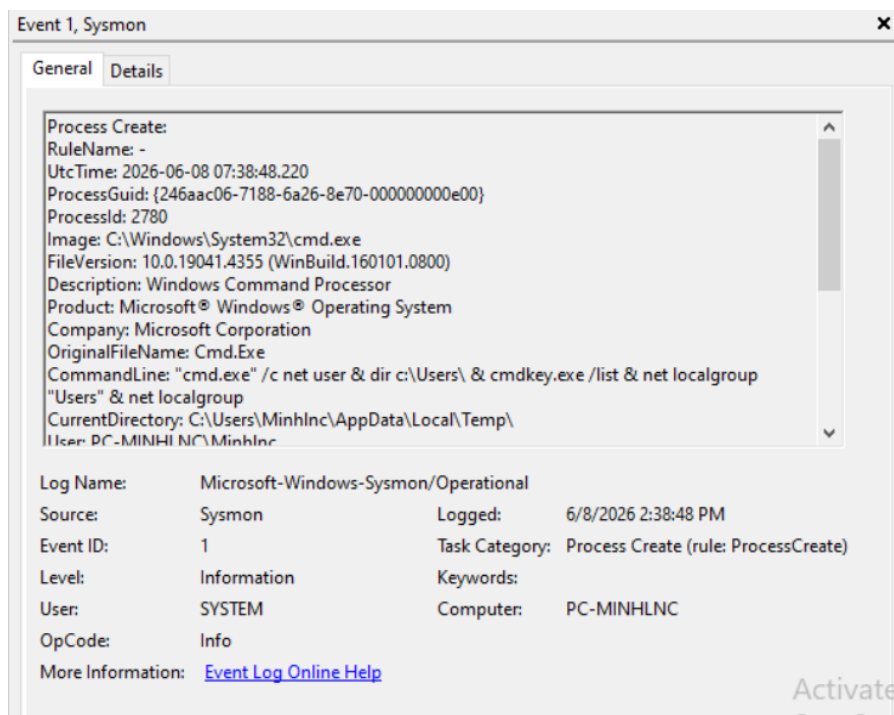
1.1.2 T1087.001 (Discovery: Local Account Discovery)

- **Khái niệm:** Kỹ thuật thu thập danh sách các tài khoản người dùng cục bộ (local users) trên hệ thống bị xâm nhập để định vị mục tiêu leo thang đặc quyền hoặc di chuyển ngang.
- **Hành vi thực thi:** Kẻ tấn công sử dụng các công cụ quản trị hệ thống tích hợp sẵn (LOLBins) như net user, net localgroup để tự động liệt kê tài khoản.
- **Dấu vết để lại:** Log tạo tiến trình (Sysmon ID 1) ghi nhận command line đặc trưng chứa từ khóa net user. Hệ thống giám sát (Hayabusa) phát hiện các chuỗi lệnh trình sát này ở mức độ Thông tin.

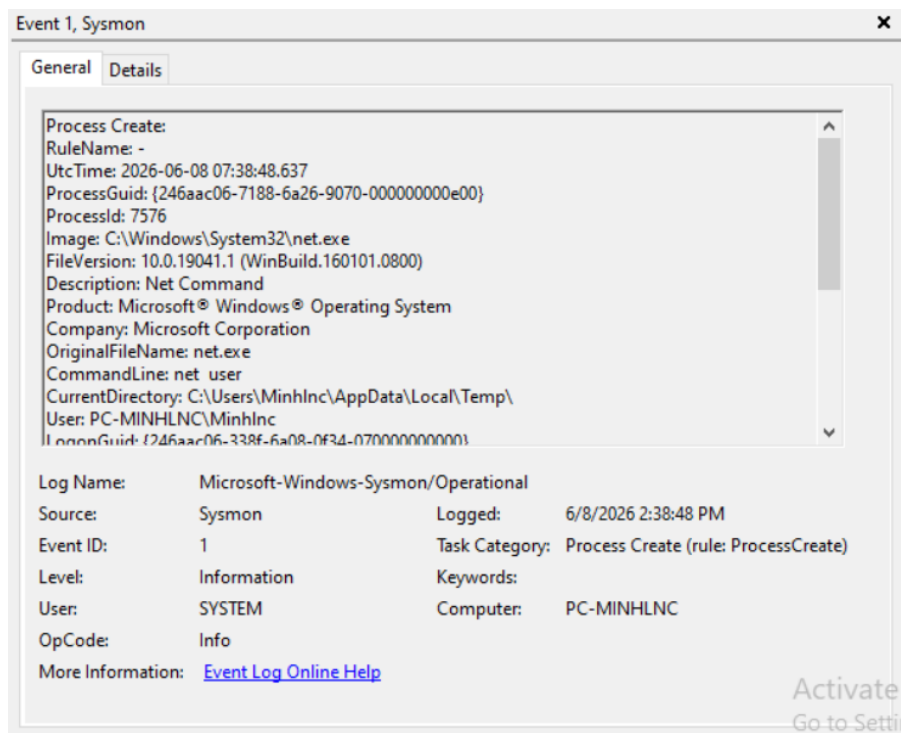
```
PS C:\Users\MinhInc\Downloads\hayabusa-3.9.0-win-x64> Invoke-AtomicTest T1087.001 -TestNumbers 8
PathToAtomsFolder = C:\AtomicRedTeam\atomics

Executing test: T1087.001-8 Enumerate all accounts on Windows (Local)
User accounts for \\PC-MINHLNC
Administrator          DefaultAccount          defaultuser0
-----
Guest                  MinhInc                 WDAGUtilityAccount
The command completed successfully.
```

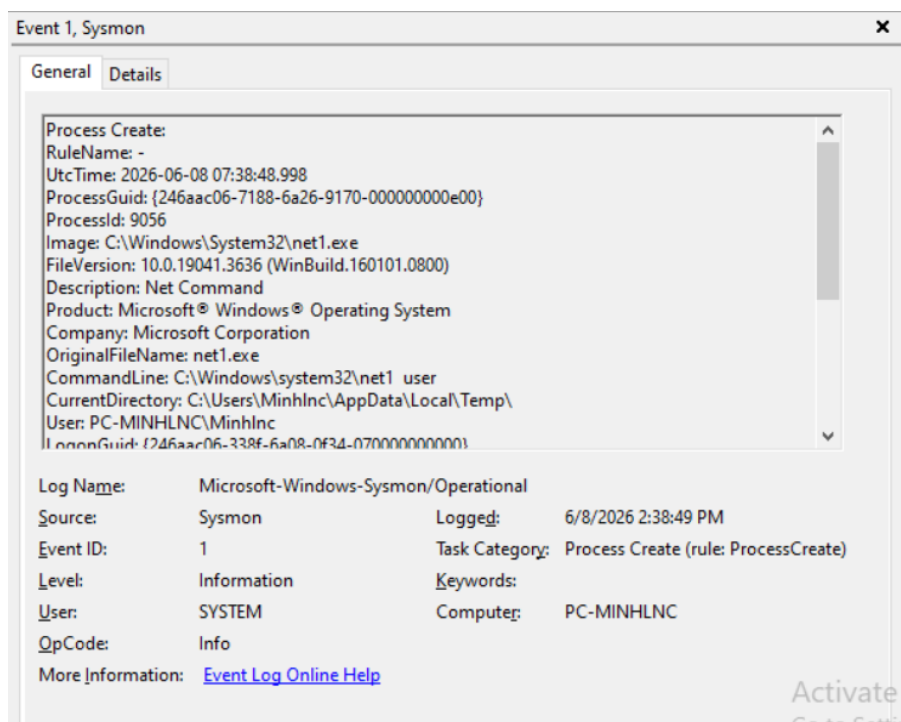
Hình 3: T1087.001-8 Enumerate all accounts on Windows (Local)



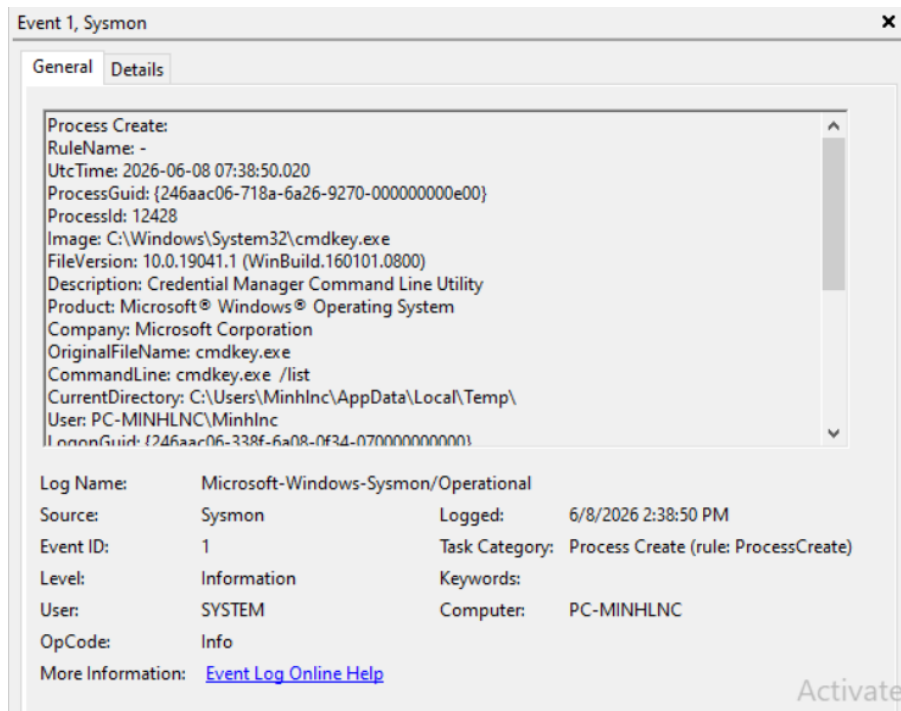
Hình 4: Log Sysmon Event ID 1 phát hiện lệnh trình sát tạo từ cmd.exe



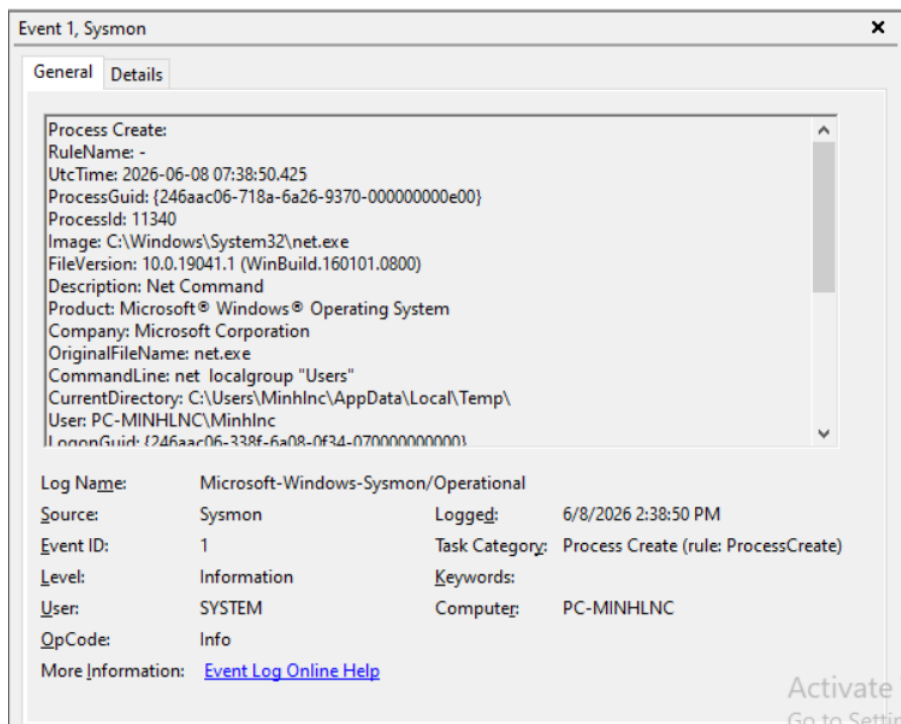
Hình 5: Log Sysmon Event ID 1 phát hiện lệnh trình sát tài khoản (net user)



Hình 6: Log Sysmon Event ID 1 phát hiện lệnh trình sát thông qua net1.exe



Hình 7: Log Sysmon Event ID 1 phát hiện lệnh truy vấn thông tin xác thực (cmdkey /list)



Hình 8: Log Sysmon Event ID 1 phát hiện lệnh liệt kê nhóm người dùng (net localgroup)

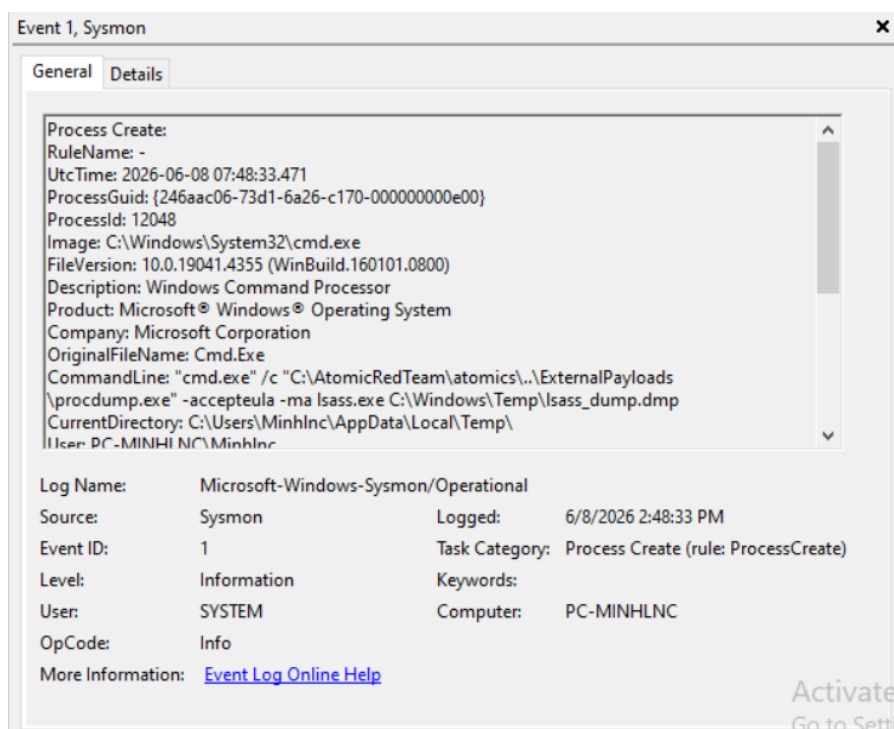
1.1.3 T1003.001 (Credential Access: OS Credential Dumping - LSASS Memory)

- **Khái niệm:** Trích xuất bộ nhớ của tiến trình Local Security Authority Subsystem Service (lsass.exe) nhằm đánh cắp thông tin xác thực (dưới dạng văn bản gốc hoặc NTLM hash) của người dùng đã đăng nhập.
- **Hành vi thực thi:** Kẻ tấn công sử dụng các công cụ chuyên dụng (như ProcDump, Mimikatz) hoặc lạm dụng thư viện hệ thống (comsvcs.dll) để kết xuất vùng nhớ của LSASS ra một file dump.
- **Dấu vết để lại:** Cảnh báo mức độ High/Critical trên các công cụ sẵn mỗi đe dọa. Ghi nhận log tạo file (Sysmon Event ID 11) với sự xuất hiện của file lạ như lsass_dump.dmp tại thư mục Temp, kèm theo tiến trình thực thi procdump.exe.

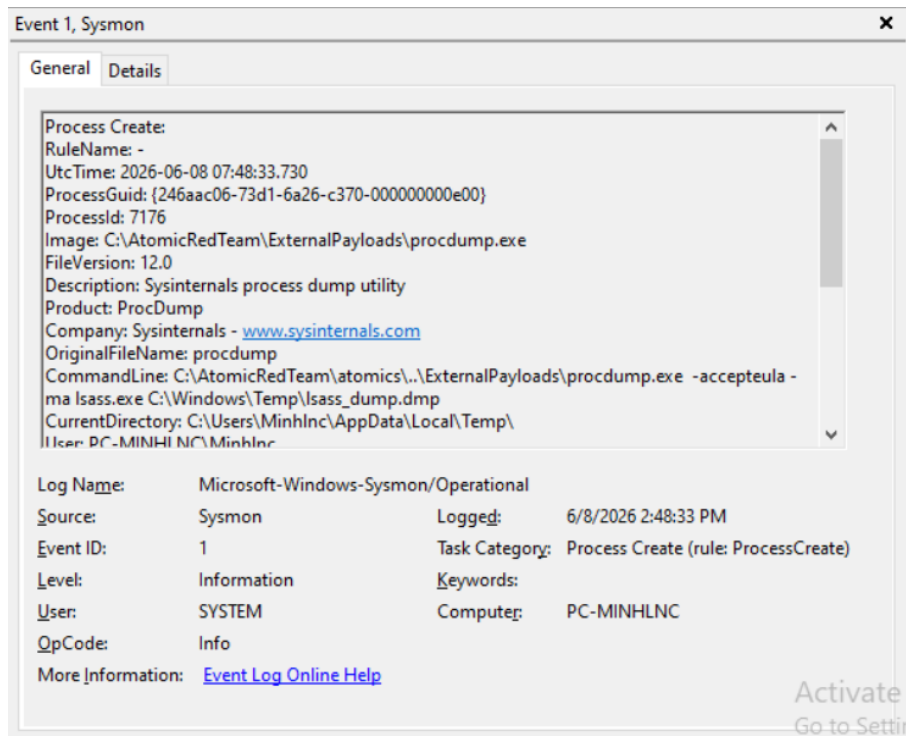
```
PS C:\Users\MinhInc\Downloads\hayabusa-3.9.0-win-x64> Invoke-AtomicTest T1003.001 -TestNumbers 1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1003.001-1 Dump LSASS.exe Memory using ProcDump
ProcDump v12.0 - Sysinternals process dump utility
Copyright (C) 2009-2026 Mark Russinovich and Andrew Richards
Sysinternals - www.sysinternals.com
[14:48:36]Dump 1 info: Available space: 58054582272
[14:48:36]Dump 1 initiated: C:\Windows\Temp\lsass_dump.dmp
[14:48:43]Dump 1 writing: Estimated dump file size is 58 MB.
[14:48:43]Dump 1 complete: 58 MB written in 7.5 seconds
[14:48:44]Dump count reached.
Exit code: -2
Done executing test: T1003.001-1 Dump LSASS.exe Memory using ProcDump
PS C:\Users\MinhInc\Downloads\hayabusa-3.9.0-win-x64>
```

Hình 9: T1003.001-1 Dump LSASS.exe Memory using ProcDump



Hình 10: Log Sysmon Event ID 1 ghi nhận cmd.exe gọi công cụ ProcDump



Hình 11: Log Sysmon Event ID 1 ghi nhận công cụ ProcDump kết xuất bộ nhớ LSASS

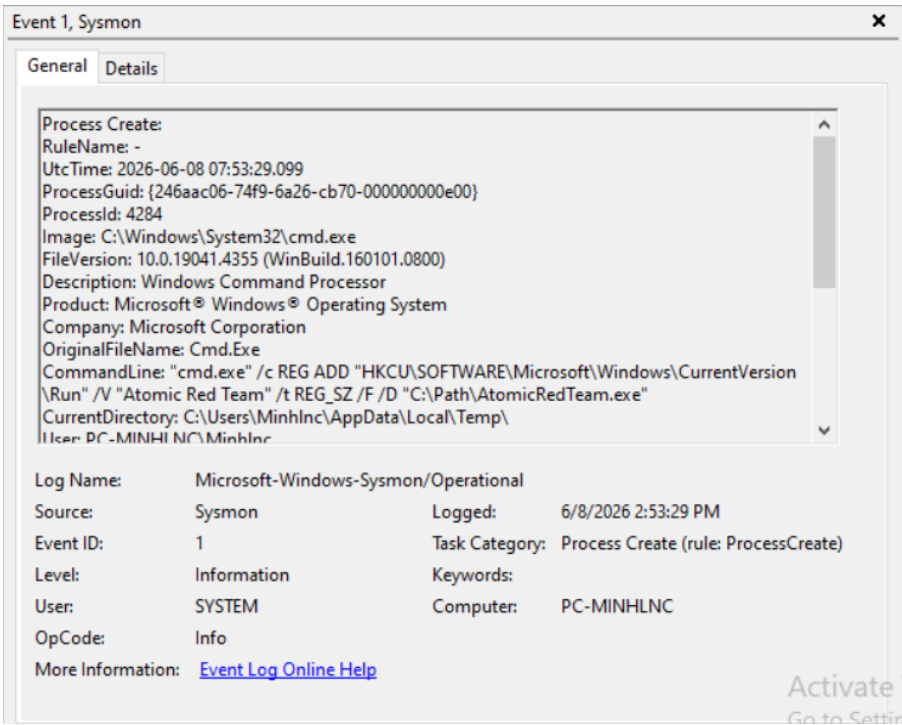
1.1.4 T1547.001 (Persistence: Run Keys)

- **Khái niệm:** Thiết lập cơ chế duy trì quyền truy cập bằng cách cấu hình cho mã độc tự động chạy ngầm mỗi khi hệ điều hành khởi động hoặc người dùng đăng nhập.
- **Hành vi thực thi:** Sử dụng công cụ reg.exe để ghi đường dẫn của file mã độc vào các khóa Registry tự động khởi chạy, điển hình là nhánh HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run.
- **Dấu vết để lại:** Log Sysmon Event ID 13 (Registry Event) ghi nhận hành vi SetValue bất thường vào các nhánh Run/RunOnce.

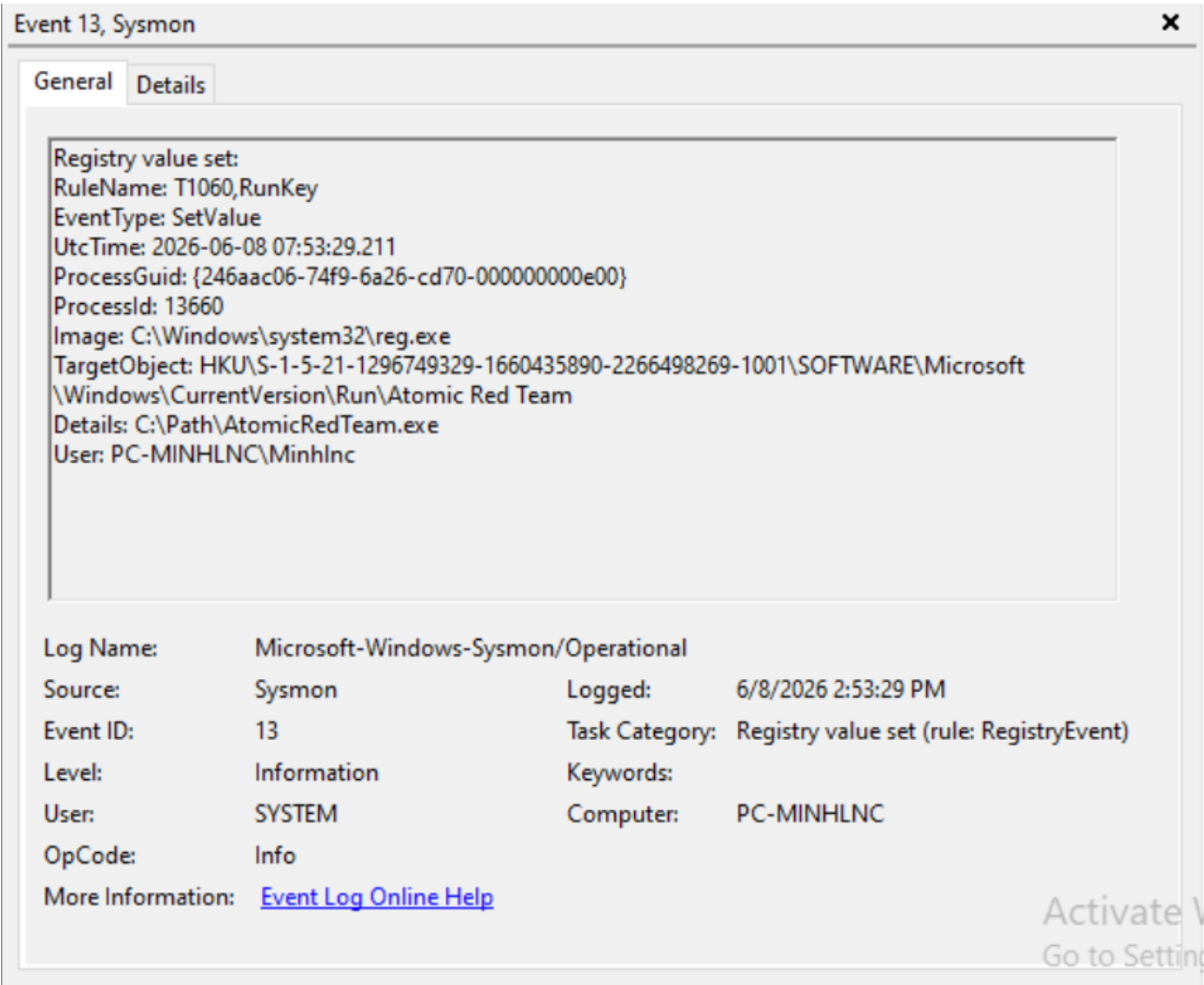
```
PS C:\Users\MinhInc\Downloads\hayabusa-3.9.0-win-x64> Invoke-AtomicTest T1547.001 -TestNumbers 1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1547.001-1 Reg Key Run
The operation completed successfully.
Exit code: 0
Done executing test: T1547.001-1 Reg Key Run
PS C:\Users\MinhInc\Downloads\hayabusa-3.9.0-win-x64>
```

Hình 12: T1547.001-1 Reg Key Run



Hình 13: Log Sysmon Event ID 1 hiển thị hành vi ghi Registry để duy trì quyền truy cập (Persistence)



Hình 14: Log Sysmon Event ID 13 hiển thị hành vi ghi Registry

2 Incident Response - Thu thập log (CDIR)

2.1 Ngữ cảnh cảnh báo

Hệ thống SOC ghi nhận trên một máy trạm có dấu hiệu chạy PowerShell bất thường, kèm theo một phiên đăng nhập thất bại trên tài khoản **Minhlnc** và một số tiến trình lạ. Đây là các dấu hiệu thỏa hiệp tiềm tàng, đủ điều kiện kích hoạt quy trình Ứng cứu sự cố (Incident Response) và thu thập chứng cứ ngay lập tức.

2.2 Mục tiêu Phase

- Thu thập log một cách an toàn, hạn chế tối đa tác động lên hiện trường.
- Đảm bảo lấy đủ dữ liệu cần thiết để có thể tái dựng toàn bộ dòng thời gian tấn công.

2.3 Nguyên tắc thu thập forensic-safe

Công cụ CDIR-Collector (Cyber Defense Institute) được thiết kế cho giai đoạn first response, ưu tiên các nguyên tắc sau để bảo toàn giá trị pháp lý của chứng cứ:

- **Thu thập, không phân tích trên máy nạn nhân:** CDIR chỉ sao chép các artifact (Event Log, Registry hive, Prefetch, MFT...) ra thư mục output, không chỉnh sửa dữ liệu gốc trên hệ thống đang điều tra.
- **Dấu chân tối thiểu:** công cụ chạy trực tiếp từ thư mục đã chuẩn bị sẵn, không cài đặt lên máy mục tiêu giảm thiểu thay đổi trạng thái hệ thống. (Việc thực thi bất kỳ công cụ nào cũng để lại một lượng vết nhất định; mục tiêu là tối thiểu hóa, không phải triệt tiêu hoàn toàn.)
- **Có nhật ký thu thập:** file collector-log ghi lại toàn bộ quá trình, các artifact đã lấy và thời điểm thực hiện phục vụ truy vết và đối chiếu.

2.4 Quá trình thu thập và Kết quả

Cấu hình thu thập tất MemoryDump và bật các nguồn cần cho điều tra (Event log, Registry, Prefetch, MFT, USN Journal, Amcache...). Các nhóm dữ liệu trọng tâm gồm:

- **Windows Event Logs:** Security.evtx, System.evtx, Microsoft-Windows-PowerShell/Operational.evtx và Microsoft-Windows-Sysmon/Operational.evtx.
- **Registry hives:** NTUSER.dat (của user Minhlnc), SOFTWARE, SYSTEM, Amcache.hve — phục vụ kiểm tra persistence và bằng chứng state.
- **Metadata:** file collector-log ghi nhận user, hostname và timezone.

Thông tin môi trường thu thập (quan trọng cho timeline):

- **Hostname:** PC-MINHLNC.
- **Timezone:** UTC+7 (giờ Việt Nam). Đây là chi tiết then chốt: log Windows lưu trường UtcTime (ví dụ 07:48:33) trong khi giao diện hiển thị giờ local (14:48:33). Toàn bộ timestamp trong báo cáo này dùng giờ local UTC+7, đã đối chiếu với UtcTime.
- **Thời điểm thu thập:** 2026-06-08 15:04 (local). Mốc này nằm ngay sau hành vi tấn công cuối cùng (14:53), xác nhận chứng cứ được thu khi hệ thống vẫn còn mới.

```

PS C:\Users\MinhInc\Downloads\cdir-collector_1.3.7\cdir-collector> .\cdir-collector.exe
CDIR Collector v1.3.7 - Data Acquisition Tool for First Response
Cyber Defense Institute, Inc.

Loading C:\Users\MinhInc\Downloads\cdir-collector_1.3.7\cdir-collector\cdir.ini...
MemoryDump is undefined
MemoryDump (1:ON 2:OFF 0:EXIT)
> 2
Memory dump: OFF
MFT: ON
Secure: ON
UsnJrnl: ON
Event log: ON
Prefetch: ON
Registry: ON
WMI: ON
SRUM: ON
Web: ON
Output Directory: C:\Users\MinhInc\Downloads\cdir-collector_1.3.7\cdir-collector\PC-MINHLNC_20260608150426
Start collecting data for analysis

```

Hình 15: Chạy công cụ CDIR-C để thu thập chứng cứ

```

Finished collecting data for analysis
Press Enter key to continue...

PS C:\Users\MinhInc\Downloads\cdir-collector_1.3.7\cdir-collector>

```

Hình 16: Quá trình thu thập CDIR-C hoàn tất thành công

This PC > Downloads > cdir-collector_1.3.7 > cdir-collector > DFIR-collector >				
	Name	Date modified	Type	Size
	Registry	6/8/2026 6:38 PM	File folder	
	WindowsEventLog	6/8/2026 6:38 PM	File folder	
	collector-log	6/8/2026 4:13 PM	Text Document	16K

Hình 17: Danh mục các dữ liệu trọng tâm được CDIR trích xuất

This PC > Downloads > cdir-collector_1.3.7 > cdir-collector > DFIR-collector > WindowsEventLog				
	Name	Date modified	Type	Size
	Microsoft-Windows-PowerShell%4Opera...	6/8/2026 2:41 PM	Event Log	12,35K
	Microsoft-Windows-Sysmon%4Operatio...	6/8/2026 3:20 PM	Event Log	65,54K
	Security	6/8/2026 3:20 PM	Event Log	20,48K
	System	6/8/2026 3:20 PM	Event Log	3,14K

Hình 18: Các file Event Log (.evtx) được thu thập

Name	Date modified	Type	Size
Amcache.hve	5/16/2026 4:01 PM	HVE File	2,041
Amcache.hve.LOG1	4/11/2026 6:54 AM	LOG1 File	251
Amcache.hve.LOG2	4/11/2026 6:54 AM	LOG2 File	121
Default_NTUSER.dat	4/13/2026 5:30 PM	DAT File	251
Default_NTUSER.dat.LOG1	12/7/2019 4:03 PM	LOG1 File	61
Default_NTUSER.dat.LOG2	12/7/2019 4:03 PM	LOG2 File	21
MinhInc_NTUSER.dat	5/16/2026 4:01 PM	DAT File	2,301
MinhInc_NTUSER.dat.LOG1	4/11/2026 7:05 AM	LOG1 File	251
MinhInc_NTUSER.dat.LOG2	4/11/2026 7:05 AM	LOG2 File	631
MinhInc_UsrClass.dat	5/16/2026 4:01 PM	DAT File	3,841
MinhInc_UsrClass.dat.LOG1	4/11/2026 7:05 AM	LOG1 File	941
MinhInc_UsrClass.dat.LOG2	4/11/2026 7:05 AM	LOG2 File	561
SAM	5/16/2026 4:02 PM	File	61
SAM.LOG1	12/7/2019 4:03 PM	LOG1 File	61
SAM.LOG2	12/7/2019 4:03 PM	LOG2 File	41
SECURITY	5/16/2026 4:02 PM	File	61
SECURITY.LOG1	12/7/2019 4:03 PM	LOG1 File	61
SECURITY.LOG2	12/7/2019 4:03 PM	LOG2 File	1
SOFTWARE	5/16/2026 4:02 PM	File	74,491
SOFTWARE.LOG1	12/7/2019 4:03 PM	LOG1 File	18,161
SOFTWARE.LOG2	12/7/2019 4:03 PM	LOG2 File	18,621
SYSTEM	5/16/2026 4:02 PM	File	11,521
SYSTEM.LOG1	12/7/2019 4:03 PM	LOG1 File	2,751
SYSTEM.LOG2	12/7/2019 4:03 PM	LOG2 File	2,041

Hình 19: Các file Registry hive được trích xuất bởi CDIR-C

3 DFIR Analysis - Phân tích log bằng Hayabusa

3.1 Mục tiêu và phương pháp

Phân tích được thực hiện **không đọc log thủ công**, mà tận dụng Hayabusa để tự động áp dụng Sigma rules sinh ra timeline cảnh báo. Điểm cốt lõi về phương pháp: thay vì đi xác nhận từng kỹ thuật theo một kịch bản biết trước, quá trình điều tra tuân theo hướng **dựa trên mức độ nghiêm trọng của cảnh báo**:

Alert Triage → Anchor Event → Pivot

Nghĩa là: định vị máy nhiễm và cảnh báo nguy hiểm nhất trước, chọn nó làm điểm neo, rồi mở rộng phân tích xoay quanh điểm neo đó (pivot ngược/xuôi thời gian, theo user và host).

3.2 Cơ sở lựa chọn nguồn log

Từ dữ liệu CDIR thu được ở Phase 2, phân tích dùng đồng thời nhiều nguồn log thay vì chỉ dựa vào Sysmon, vì mỗi nguồn trả lời một loại câu hỏi khác nhau và không thể thay thế cho nhau:

Computer	OS information	UpTime	Timezone	Events
PC-MINHLNC	Windows 10 (22H1) (2022/05/10)	0Y 0M 22d 23h 16m 41s	SE Asia Standard Time	84,300
WIN-LD3N903MR5D	Windows 10 (22H1) (2022/05/10)	0Y 0M 0d 0h 3m 13s		152
DESKTOP-43QU7FB	Windows 10 (22H1) (2022/05/10)	0Y 0M 0d 0h 14m 8s	Pacific Standard Time	122

Hình 20: Khảo sát nhanh bằng lệnh `computer-metrics` của Hayabusa

- **Sysmon Operational:** nguồn chính cho process creation (Event ID 1) và registry modification (Event ID 13) Windows Security log mặc định không ghi command line đầy đủ, Sysmon bù vào khoảng trống này.
- **Security.evtx:** nguồn duy nhất xác nhận logon/logoff (Event ID 4624/4625) Sysmon không log loại sự kiện này. Dùng để xác định user và kiểm tra lateral movement qua lệnh logon-summary.
- **Microsoft-Windows-PowerShell/Operational:** ghi nội dung script đã decode (Event ID 4104) cần thiết nếu attacker dùng PowerShell encoded/obfuscated, vì Sysmon chỉ thấy command line bề mặt.
- **System.evtx:** bắt các persistence mechanism khác ngoài Run Key, đặc biệt Service installation (Event ID 7045).
- **Registry hives (NTUSER.dat, Amcache.hve):** bằng chứng state độc lập với log không bị ảnh hưởng nếu attacker tamper hoặc xóa Event Log.

3.3 Bước 1: Sanity check — Khảo sát tổng quan dataset

Trước khi đi vào săn lùng, khảo sát nhanh dataset bằng chức năng metrics của Hayabusa để hiểu quy mô dữ liệu:

- **Số máy:** 3 máy trong dataset PC-MINHLNC, WIN-LD3N903MR5D, và DESKTOP-43QU7FB.
- **Tổng số event xử lý:** khoảng 85000 event.

Phương pháp: Số lượng log sinh ra không phản ánh mức độ nguy hiểm một máy hoạt động nhiều một cách bình thường cũng sinh rất nhiều log. Tiêu chí để khoanh vùng là mức độ nghiêm trọng của cảnh báo, được xử lý ở Bước 2.

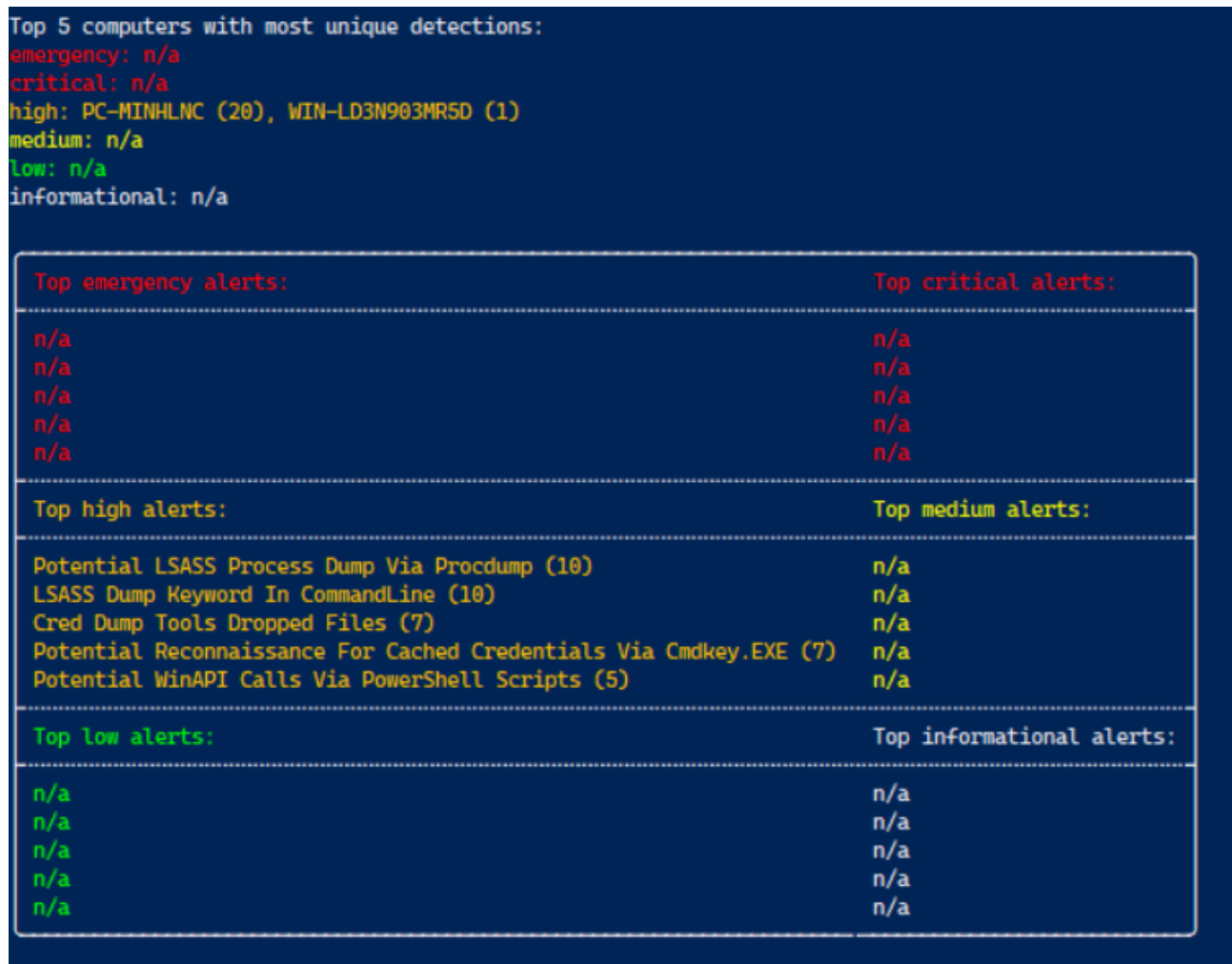
3.4 Bước 2: Triage theo mức độ nghiêm trọng — Xác định máy nghi nhiễm

Chạy `csv-timeline` với **lựa chọn 1 — Core rules** (status: test/stable, level: high/critical). Đây là ruleset hẹp, độ tin cậy cao, ít false positive, phù hợp để triage nhanh và quyết liệt.

```
? Which set of detection rules would you like to load? >
> 1. Core (2,211 rules) ( status: test, stable | level: high, critical )
2. Core+ (3,907 rules) ( status: test, stable | level: medium, high, critical )
3. Core++ (4,217 rules) ( status: experimental, test, stable | level: medium, high, critical )
4. All alert rules (4,806 rules) ( status: * | level: low+ )
5. All event and alert rules (4,924 rules) ( status: * | level: informational+ )
```

Hình 21: Các lựa chọn ruleset khi xuất `csv-timeline` bằng Hayabusa

Kết quả: trong toàn bộ dataset (3 máy), phát sinh **20 cảnh báo mức High**, và toàn bộ thuộc về **PC-MINHLNC**. Hai máy còn lại (WIN-LD3N903MR5D, DESKTOP-43QU7FB) không ghi nhận alert High đáng kể nào.



Hình 22: Hayabusa tổng hợp số lượng alert High theo từng máy — toàn bộ tập trung tại PC-MINHLNC

Kết luận triage: PC-MINHLNC là máy nghi nhiễm chính, xác định ngay từ vòng quét đầu tiên dựa trên mức độ nghiêm trọng.

3.5 Bước 3: Chọn Anchor Event

Xem chi tiết 20 cảnh báo High trên PC-MINHLNC, nhiều cảnh báo cùng trở về một cụm hành vi: "Potential LSASS Process Dump Via Procdump", "LSASS Dump Keyword In CommandLine", "Cred Dump Tools Dropped Files", "DMP/HDMP File Creation".

Timestamp	RuleTitle	Levi	Computer	Chanr	Details
2026-06-08 14:48	Cred Dump Tools Dropped Files	high	PC-MINHLNC	Sysmon	Path: C:\AtomicRedTeam\ExternalPayloads\procdump64.exe 礎 Proc: C:\AtomicRedTeam\ExternalPayloads\procdump.exe 礎
2026-06-08 14:48	LSASS Process Memory Dump Files	high	PC-MINHLNC	Sysmon	Path: C:\Windows\Temp\lsass_dump.dmp 礎 Proc: C:\AtomicRedTeam\ExternalPayloads\procdump64.exe 礎 PID: 5060 礎 PC
2026-06-08 14:38	Potential Reconnaissance For Cached Cre	high	PC-MINHLNC	Sysmon	Cmdline: cmdkey.exe /list 礎 Proc: C:\Windows\System32\cmdkey.exe 礎 User: PC-MINHLNC\MinhInc 礎 ParentCmdline: "cm
2026-06-08 14:48	LSASS Dump Keyword In CommandLine	high	PC-MINHLNC	Sysmon	Cmdline: "cmd.exe" /c "C:\AtomicRedTeam\atomics\...\ExternalPayloads\procdump.exe" -accepteula -ma lsass.exe C:\Window
2026-06-08 14:48	LSASS Dump Keyword In CommandLine	high	PC-MINHLNC	Sysmon	Cmdline: "cmd.exe" /c "C:\AtomicRedTeam\atomics\...\ExternalPayloads\procdump.exe" -accepteula -ma lsass.exe C:\Windows\Temp\lsass_d
2026-06-08 14:48	LSASS Dump Keyword In CommandLine	high	PC-MINHLNC	Sysmon	Cmdline: "cmd.exe" /c "C:\AtomicRedTeam\atomics\...\ExternalPayloads\procdump.exe" -accepteula -ma lsass.exe C:\Windows\Temp\lsass_d
2026-06-08 14:48	Potential LSASS Process Dump Via Procd	high	PC-MINHLNC	Sysmon	Cmdline: "cmd.exe" /c "C:\AtomicRedTeam\atomics\...\ExternalPayloads\procdump.exe" -accepteula -ma lsass.exe C:\Window
2026-06-08 14:48	Potential LSASS Process Dump Via Procd	high	PC-MINHLNC	Sysmon	Cmdline: "cmd.exe" /c "C:\AtomicRedTeam\atomics\...\ExternalPayloads\procdump.exe" -accepteula -ma lsass.exe C:\Windows\Temp\lsass_d
2026-06-08 14:48	Potential LSASS Process Dump Via Procd	high	PC-MINHLNC	Sysmon	Cmdline: "cmd.exe" /c "C:\AtomicRedTeam\atomics\...\ExternalPayloads\procdump.exe" -accepteula -ma lsass.exe C:\Windows\Temp\lsass_d
2026-06-08 14:48	Disable Windows Defender Functionalitie	high	PC-MINHLNC	Sysmon	EventType: SetValue 礎 RegKey: HKLM\SOFTWARE\Microsoft\Windows Defender\Real-Time Protection\DisableRealTimeMonit

Hình 23: Danh sách các cảnh báo mức High ghi nhận trên PC-MINHLNC

Việc chọn cảnh báo nào làm **điểm neo (anchor event)** không dựa trên thứ tự thời gian hay số lượng, mà dựa trên **hai tiêu chí: tính bất thường của hành vi và mức độ tác động.**

Xét về hành vi có "phổ thông" không, có admin/user nào làm vậy không?

Tiến trình lsass.exe nắm giữ toàn bộ thông tin xác thực của các phiên đăng nhập (mật khẩu dạng rõ, NTLM hash, Kerberos ticket). Trong vận hành bình thường, **không có quản trị viên hay người dùng thông thường** nào có nhu cầu hợp lệ để kết xuất toàn bộ vùng nhớ của tiến trình này đây không phải thao tác bảo trì, vá lỗi hay chẩn đoán hàng ngày. Khi một công cụ bên thứ ba (procdump.exe) chủ động đọc và ghi bộ nhớ LSASS ra file, gần như chắc chắn đó là hành vi đánh cắp thông tin xác thực (T1003.001); không tồn tại cách giải thích lành tính nào khác. Chính tính không thể giải thích lành tính này khiến nó vượt trội về độ đáng ngờ so với các alert còn lại.

Xét về mức độ tác động: đây là alert ở mức High và là mất xích có sức tàn phá lớn nhất trong toàn chuỗi một khi credential bị lộ, kẻ tấn công có thể mở đường cho Lateral Movement và đoạt quyền toàn domain.

Vì vậy, cảnh báo sau được chọn làm **anchor event**:

2026-06-08 14:48:33 Rule "LSASS Dump Keyword In CommandLine"
(High)

procdump.exe -accepteula -ma lsass.exe C:\Windows\Temp\lsass_dump.dmp

Anchor đã thực thi thành công, không phải nỗ lực bất thành. Output của ProcDump ghi nhận "58 MB written" và Hayabusa bắt được cảnh báo "DMP/HDMP File Creation" ứng với file C:\Windows\Temp\lsass_dump.dmp. Bằng chứng command line và bằng chứng artifact (file dump tồn tại) củng cố lẫn nhau: credential đã thực sự bị kết xuất.

3.6 Bước 4: Mở rộng ruleset để lấy đủ ngữ cảnh

Vì sao phải chuyển từ ruleset hẹp sang ruleset đầy đủ? Ruleset hẹp (option 1, high/critical) chỉ làm nổi các phần nguy hiểm nhất đủ để định vị máy nhiễm và anchor, nhưng che mất phần thân của chuỗi tấn công. Cụ thể:

- Các lệnh trình sát (net user, net localgroup, cmdkey /list) chỉ sinh alert ở mức Low.
- Hành vi ghi Run Key để duy trì truy cập chỉ ở mức **Medium**.

Nếu dừng ở high-only, ta chỉ thấy cú dump LSASS đơn độc mà không biết điều gì dẫn đến nó và điều gì xảy ra sau nó. Do đó, sau khi đã khoanh vùng PC-MINHLNC, tiến hành chạy lại với **lựa chọn 5 — All event and alert rules** (bao gồm cả mức low+) **giới hạn trên đúng máy này** để tái dựng đầy đủ ngữ cảnh quanh anchor.

Timestamp	RuleTitle	Lev	Computer	Chanr	Ei	Details
2026-06-08 14:32	Non Interactive Powershell	low	PC-MINHLNC	Sysmon	1	Cmdline: "powershell.exe" & {Start-Process ""C:\AtomicRedTeam\atomics\..\ExternalPayload
2026-06-08 14:35	Suspicious Execution of l	low	PC-MINHLNC	Sysmon	1	Cmdline: "C:\Windows\system32\HOSTNAME.EXE" 礎 Proc: C:\Windows\System32\HOSTNAN
2026-06-08 14:35	Local Accounts Discovery	low	PC-MINHLNC	Sysmon	1	Cmdline: "C:\Windows\system32\whoami.exe" 礎 Proc: C:\Windows\System32\whoami.exe 礎
2026-06-08 14:48	LSASS Dump Keyword In high	high	PC-MINHLNC	Sysmon	1	Cmdline: "cmd.exe" /c "C:\AtomicRedTeam\atomics\..\ExternalPayloads\procdump.exe" -acce
2026-06-08 14:48	File Created (Sysmon Ale	med	PC-MINHLNC	Sysmon	11	Rule: EXE 礎 Path: C:\AtomicRedTeam\ExternalPayloads\procdump64.exe 礎 Proc: C:\AtomicF
2026-06-08 14:48	Cred Dump Tools Droppi	high	PC-MINHLNC	Sysmon	11	Path: C:\AtomicRedTeam\ExternalPayloads\procdump64.exe 礎 Proc: C:\AtomicRedTeam\Exti
2026-06-08 14:48	Creation of an Executabl	low	PC-MINHLNC	Sysmon	11	Path: C:\AtomicRedTeam\ExternalPayloads\procdump64.exe 礎 Proc: C:\AtomicRedTeam\Exti
2026-06-08 14:48	LSASS Dump Keyword In high	high	PC-MINHLNC	Sysmon	1	Cmdline: C:\AtomicRedTeam\atomics\..\ExternalPayloads\procdump.exe -accepteula -ma lsas
2026-06-08 14:48	DMP/HDMP File Creation	low	PC-MINHLNC	Sysmon	11	Path: C:\Windows\Temp\lsass_dump.dmp 礎 Proc: C:\AtomicRedTeam\ExternalPayloads\pro
2026-06-08 14:53	Potential Persistence Att	med	PC-MINHLNC	Sysmon	1	Cmdline: REG ADD "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /V "Atomic F
2026-06-08 14:53	Direct Autorun Keys Mo	med	PC-MINHLNC	Sysmon	1	Cmdline: REG ADD "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /V "Atomic F
2026-06-08 14:53	CurrentVersion Autorun	med	PC-MINHLNC	Sysmon	13	EventType: SetValue 礎 RegKey: HKU\S-1-5-21-1296749329-1660435890-2266498269-1001\SC

Hình 24: Timeline đầy đủ trên PC-MINHLNC sau khi mở rộng ruleset (option 5)

3.7 Bước 5: Pivot xung quanh Anchor Event

Pivot 1 — Ngược thời gian: điều gì dẫn đến anchor?

Lọc các event cùng User và Computer với anchor, timestamp trước 14:48:33:

Task 1 - DFIR

- **14:32:50** Rule "Non Interactive PowerShell Process Spawned": powershell.exe khởi chạy T1059.003_script.bat điểm khởi đầu của session tấn công (T1059.003 Execution).
- **14:35:17–14:38:50** Rule "Local Accounts Discovery" và "Suspicious Execution of Hostname": cmd.exe chạy chuỗi hostname.exe, net user, cmdkey /list, net localgroup trình sát hệ thống (T1087.001, T1082) trước khi dump credential.

Nhận định: anchor không phải hành vi đơn lẻ nó là bước cuối trong chuỗi **Execution** → **Discovery** → **Credential Access**. Attacker dùng các LOLBins có sẵn của Windows (powershell.exe, cmd.exe, net.exe) trước khi gọi công cụ bên thứ ba procdump.exe không có malware tùy chỉnh.

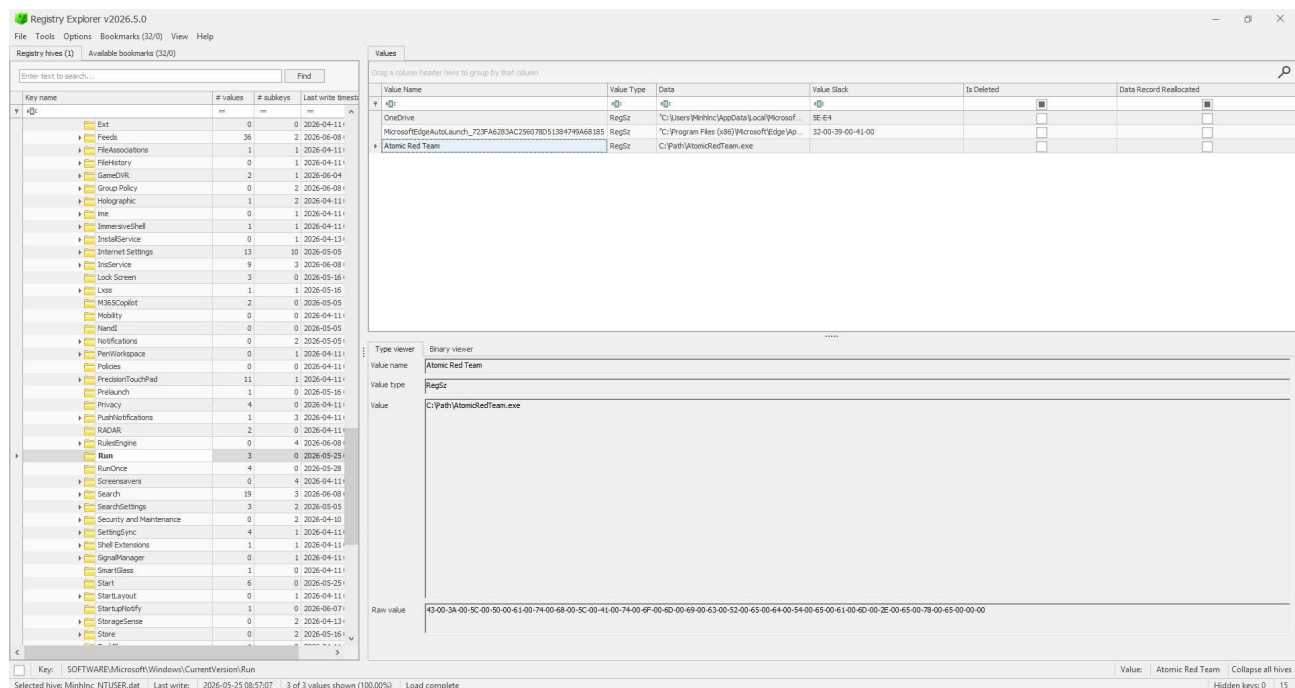
Pivot 2 — Xuôi thời gian: điều gì xảy ra ngay sau anchor?

Lọc cùng User/Computer, timestamp sau 14:48:33:

- **14:53:29** — Rule "Direct Autorun Keys Modification" và "Potential Persistence Attempt Via Run Keys Using Reg.EXE" (Medium):
cmd.exe /c REG ADD "HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /V "Atomic Red Team" /t REG_SZ /F /D "C:\Path\AtomicRedTeam.exe"

Nhận định: chỉ 5 phút sau khi dump LSASS thành công, attacker thiết lập ngay persistence — hành vi điển hình của giai đoạn "củng cố quyền truy cập" sau khi đã đánh cắp credential.

Xác nhận persistence bằng bằng chứng state. Để khẳng định persistence **thực sự có hiệu lực** — không chỉ là log ghi lại hành động, mà giá trị thật sự tồn tại trên hệ thống — tiến hành phân tích trực tiếp Registry hive MinhInc_NTUSER.dat bằng Registry Explorer:



Hình 25: Registry Explorer xác nhận giá trị "Atomic Red Team" tồn tại tại Run Key của user MinhInc

Tại nhánh ROOT\Software\Microsoft\Windows\CurrentVersion\Run, giá trị **Atomic Red Team** thực sự tồn tại, trỏ đến C:\Path\AtomicRedTeam.exe. Bằng chứng state (Registry hive) corroborate với bằng chứng log (Sysmon Event ID 13), đúng nguyên tắc đa nguồn ở mục 3.2. Điều này khẳng định payload sẽ tự động kích hoạt ngầm mỗi khi user MinhInc đăng nhập kể cả sau khi reboot. **Kết luận: CÓ persistence** (T1547.001).

Pivot 3 — User & Host: phạm vi ảnh hưởng đến đâu?

Chạy logon-summary trên Security.evtx để xác định user bị lợi dụng và kiểm tra khả năng lan rộng (lateral movement):

Logon Summary:
Successful Logons:

Successful	Event	Target Account	Target Computer	Source Computer	Source IP Address
8370	Sec 4624	SYSTEM	PC-MINHLNC	-	-
2	Sec 4624	MinhInc	PC-MINHLNC	PC-MINHLNC	127.0.0.1

Failed Logons:

Failed	Event	Target Account	Target Computer	Source Computer	Source IP Address
1	Sec 4625	MinhInc	PC-MINHLNC	PC-MINHLNC	127.0.0.1

Hình 26: Kết quả logon-summary trên PC-MINHLNC

- **User bị lợi dụng:** MinhInc 2 đăng nhập thành công + 1 thất bại (Event ID 4624/4625), toàn bộ từ Source IP **127.0.0.1**.
- **Lateral Movement:** không ghi nhận Logon Type 3 (Network Logon) từ nguồn ngoài; toàn bộ Source Computer đều là PC-MINHLNC. Không có phiên đăng nhập nào từ IP/hostname của máy khác trong mạng.

Kết luận: KHÔNG có Lateral Movement tại thời điểm phân tích. Kẻ tấn công dừng lại ở PC-MINHLNC. Tuy nhiên, do LSASS đã bị dump thành công, **rủi ro lateral movement là rất cao** nếu hệ thống không được cô lập ngay.

3.8 Ghi chú: Phạm vi nguồn log trong kết quả phân tích

Toàn bộ alert xuất hiện trong file timeline đều thuộc nguồn Sysmon. Điều này không đồng nghĩa các nguồn khác không được kiểm tra — Sigma rule chỉ tạo alert khi nội dung event khớp pattern đáng ngờ, không phụ thuộc vào việc log đó có tồn tại hay không:

- **Security.evtx:** được phân tích riêng qua logon-summary (Hình 26) không nằm trong CSV alert vì đây là lệnh thống kê riêng, không qua bộ lọc Sigma.
- **PowerShell Operational:** không có alert vì nội dung script (Start-Process gọi file .bat) không chứa keyword độc hại (không base64, không IEX, không obfuscation).
- **System.evtx:** không có alert vì không có Service nào được tạo (T1543.003) trong kịch bản này.

Đây là kết quả phù hợp với bản chất cuộc tấn công: attacker dùng kỹ thuật living off the land đơn giản, không obfuscation hay evasion nên chỉ Sysmon (giám sát process/registry trực tiếp) mới phát hiện được hành vi.

4 Báo cáo DFIR

4.1 Executive Summary

Kết luận: Hệ thống đã bị xâm nhập.

Mức độ nghiêm trọng: nghiêm trọng (Critical) - Kẻ tấn công đã thực thi thành công mã độc, thực hiện trình sát hệ thống, thiết lập cơ chế nằm vùng và đặc biệt là có hành vi trích xuất thành công thông tin xác thực từ bộ nhớ LSASS. Việc lộ lọt NTLM hash và mật khẩu dạng rõ tiềm ẩn rủi ro cực lớn dẫn đến Lateral Movement và thâm tóm toàn bộ domain nếu không được can thiệp kịp thời.

4.2 Attack Timeline

Các hành vi tấn công được ghi nhận theo trình tự thời gian sau:

Thời gian	Sự kiện	MITRE Technique
2026-06-08 14:32	Thực thi mã PowerShell bất thường	T1059.003 (Execution)
2026-06-08 14:35	Chạy lệnh hostname, net user	T1087.001 (Discovery)
2026-06-08 14:48	Truy cập bộ nhớ lsass.exe	T1003.001 (Credential Access)
2026-06-08 14:53	Thay đổi khóa Registry khởi động	T1547.001 (Persistence)

Bảng 1: Chuỗi sự kiện tấn công (Kill Chain)

4.3 Indicators of Compromise (IOCs)

- **Tên process đáng ngờ:** powershell.exe, cmd.exe (chạy lệnh bất thường), procdump.exe.
 - procdump.exe -accepteula -ma lsass.exe C:\Windows\Temp\lsass_dump.dmp
 - cmd.exe /c net user & dir c:\Users\ & cmdkey.exe /list & net localgroup "Users"& net localgroup
- **Registry key:** Thay đổi tại các nhánh liên quan đến Autorun/Run Keys:
HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\Atomic Red Team.

4.4 Khuyến nghị

- **Về mặt hệ thống:** Tiến hành cô lập ngay lập tức máy tính bị nhiễm (PC-MINHLNC) khỏi mạng nội bộ. Bắt buộc thay đổi mật khẩu của toàn bộ tài khoản có phiên đăng nhập trên máy tính này do lo ngại LSASS đã bị dump thành công.
- **Detection rule cần bổ sung:**
 - Bổ sung luật cảnh báo trên SIEM đối với các hành vi trích xuất thành công thông tin xác thực truy vấn như net user diễn ra liên tục trong thời gian ngắn.
 - Cấu hình SIEM (tích hợp Sysmon Event ID 10 (Process Access)) để giám sát và tạo cảnh báo cho các tiến trình lạ không được ký duyệt chọc vào bộ nhớ lsass.exe.
 - Cấu hình SIEM (tích hợp Sysmon Event ID 13) để kích hoạt tự động cảnh báo mức độ cao khi phát hiện có tiến trình thực thi hành vi SetValue vào nhánh HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run.